HANIKA ANGLICAN INTEGRATED POLYTECHNIC (HAIP) · Data Mining and Data Warehousing · FA1 Group Work

RBAC Policy

Roles, permissions and access rules

Project: University Library Analytics Data Warehouse

Group: **Group X** (replace with your group number)

Members: Member 1 (Data Architect) · Member 2 (ETL Specialist) · Member 3 (Analytics & Security Lead)

Database: SQLite 3.53.1 · ETL: Python 3 + pandas · Dashboards: Power BI Desktop

Submission: November 2, 2026 · Presentation: November 6, 2026

Contents

1. Purpose and scope
2. Roles
3. Permission matrix
4. User accounts
5. Joining, moving and leaving
6. Rules for data use
7. Monitoring and review

1. Purpose and scope

This policy defines **who may see and do what** in the University Library data warehouse (`library_dw.db`, its backups, the Power BI reports and the source exports). It applies to every library employee, department head, analyst, IT administrator and automated job.

Principles

1. **Least privilege** - every person gets the smallest set of rights needed for the job.
2. **Need to know** - department heads see only their own department.
3. **Privacy by design** - the real StudentID is visible only to administrators; everyone else sees `STU-****-001`.
4. **Accountability** - every login, every query and every change is recorded in `audit_log`.
5. **Separation of duties** - the account that loads data (ETL) is not the account that reads reports, and neither can change security settings.

2. Roles

Role	Who	Purpose
`dw_admin`	IT administrator of the library (2 people max)	maintain the database, users, security and backups
`dw_etl`	the automated ETL job (`etl_service`)	load the nightly data
`dw_analyst`	Library Director, data analysts, the Power BI service account	read and analyse all library usage, without personal data
`dw_dept_head`	heads of department / deans	follow the usage of **their own** department
`dw_backup`	the backup job (`backup_user`)	copy the database for backups

3. Permission matrix

Object	dw_admin	dw_etl	dw_analyst	dw_dept_head	dw_backup
Fact tables (`fact_*`)	read / write	read / write	**read**	- (only through own-department copies)	read
Dimension tables (`dim_*`)	read / write	read / write	read	-	read
`dim_student.student_id` (real ID)	read	write	**blocked (masked)**	blocked	read (file copy)
`dim_student.student_id_masked`	read	write	read	read (in own copies)	read
Own-department data (`my_*`)	-	-	-	**read**	-
Staging (`stg_*`), rules (`map_*`), ETL logs	read / write	read / write	-	-	read
Security tables (`sec_*`)	read / write	**-**	-	-	read (file copy)
`audit_log`	read	-	-	-	read (file copy)
Create / change / delete anything	yes	data only	**no**	**no**	**no**

The same matrix is stored in the database (tables `sec_roles`, `sec_role_permissions`, script 06) and enforced by `secure_access.py` (see *security_implementation.pdf*).

4. User accounts

Account	Role	Department	Type
lib_admin	dw_admin	-	person
etl_service	dw_etl	-	service (scheduled job)
backup_user	dw_backup	-	service (scheduled job)
director	dw_analyst	-	person
analyst_amina	dw_analyst	-	person
powerbi_reader	dw_analyst	-	service (Power BI refresh)
head_cs	dw_dept_head	CS	person
head_eng	dw_dept_head	ENG	person
head_bus	dw_dept_head	BUS	person

Account rules

- One account per person - accounts are **never shared**.
- Passwords: at least 12 characters with upper case, lower case, digit and symbol; changed every **90 days**; stored only as a salted PBKDF2-SHA256 hash (200,000 rounds).
- After **3 wrong passwords** the account is locked for 24 hours (an admin can unlock it earlier after checking the identity).
- Service accounts (`etl_service`, `backup_user`, `powerbi_reader`) are not used by people; their passwords are kept by the admin and rotated every 6 months.

5. Joining, moving and leaving

Event	Action	Who	When
New employee / new head	request form signed by the Library Director → account created with the role of the job	admin	within 2 working days
Change of job or department	role / department changed; old rights removed the same day	admin	same day
Leaving the university	account disabled (`is_active = 0`), never deleted (keeps the audit trail)	admin	last working day
Every 6 months	access review: the Director checks the user list against the staff list	Director + admin	January and July

6. Rules for data use

- Library data may only be used for library management and planning.
- Exports (Excel, CSV, screenshots) must not contain real student IDs; only aggregated or masked data may leave the library.
- Personal data is never sent by e-mail or chat; reports are shared through the Power BI service with role-based access.

- Salary or HR information is **not** stored in the warehouse (data minimisation). If ever needed, it goes in a separate table readable only by `dw_admin`.
- Any suspected misuse or data leak is reported to the Library Director and IT security within 24 hours.

7. Monitoring and review

- `audit_log` is reviewed **weekly** by the admin (refused queries, failed logins, changes to student data) using `SELECT * FROM v_audit_report`.
- Repeated refused queries by the same user → conversation with the user and the Director.
- This policy is reviewed **once a year** or when the system changes.